



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Rockwell Automation FLEX I/O EtherNet/IP Adapters

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Rockwell Automation FLEX I/O EtherNet/IP Adapters - Vulnerability Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CISA and Rockwell Automation disclosed two vulnerabilities affecting Rockwell Automation FLEX I/O EtherNet/IP adapter firmware 2.012 for the 1794-AENTR and 1794-AENTRXT catalog families. The more severe issue, CVE-2026-0647, is a missing-authentication flaw in the adapter embedded web server that allows an unauthenticated attacker to change the device web-interface password through a crafted HTTP GET request. The second issue, CVE-2026-0646, is a CIP protocol memory-handling defect that can fault the adapter, disconnect associated I/O modules, and require manual reset to recover.

Lost Boys Cyber assesses this advisory as high priority for industrial environments that operate affected FLEX I/O adapter firmware on routable plant, engineering, maintenance, or vendor-access networks. The affected devices bridge distributed FLEX I/O modules to EtherNet/IP networks and Logix controllers; therefore, exploitation can have operational consequences even when the device itself is not a Windows or Linux host. The primary risks are unauthorized web interface control, account takeover of device management access, and loss of availability for connected I/O.

No known public exploitation was reported by CISA or Rockwell Automation at release time, and Rockwell marks the vulnerabilities as not known exploited. That reduces immediate incident likelihood, but it does not remove urgency. Both issues are network reachable, require no privileges, require no user interaction, and affect devices that may sit in long-lived OT segments where firmware remediation windows are constrained.

Field	Assessment
Report ID	LBC-VTI-2026-082
Report Type	Vulnerability Threat Intelligence
Advisory	CISA ICSA-26-167-05 / Rockwell Automation SD1775
Primary Products	FLEX I/O EtherNet/IP Adapters 1794-AENTR and 1794-AENTRXT
Affected Firmware	2.012
Corrected Firmware	2.013
Highest Severity	Critical, CVSS v3.1 9.4 for CVE-2026-0647
Critical Infrastructure Sector	Critical Manufacturing; worldwide deployment
Exploitation Status	No known exploitation reported by CISA or Rockwell at publication
Analyst Confidence	High for affected versions, fix guidance, and scoring; medium for environment-specific exposure until asset inventory is validated

2. Intelligence Requirement

This report addresses the following intelligence requirement: What do the Rockwell Automation FLEX I/O EtherNet/IP adapter vulnerabilities mean for defenders responsible for manufacturing, industrial automation, and OT-adjacent network environments, and what actions should be prioritized within the next maintenance cycle?

Requirement	Analytic Answer
What changed?	Rockwell disclosed two vulnerabilities in FLEX I/O EtherNet/IP adapter firmware 2.012: CIP-triggered denial of service and unauthenticated web password change.
Who is exposed?	Operators of 1794-AENTR and 1794-AENTRXT adapters running firmware 2.012, especially where embedded web interfaces or

	EtherNet/IP/CIP traffic are reachable from engineering, vendor, or broader corporate networks.
What is the likely attacker path?	Network access to TCP/80 or TCP/443 for the embedded web server, or TCP/44818 and UDP/44818 for EtherNet/IP/CIP, followed by crafted request delivery.
What should defenders do first?	Inventory affected catalog numbers and firmware, update to firmware 2.013, restrict management/CIP reachability, and monitor for abnormal HTTP password-change attempts or CIP fault patterns.
What is not known?	The public advisories do not publish the specific HTTP endpoint used for CVE-2026-0647, a proof of concept, exploit payload bytes, or confirmed exploitation telemetry.

Analyst assumptions: this report treats CISA ICSA-26-167-05, the CISA CSAF JSON, and Rockwell Automation SD1775 as authoritative for product scope, version scope, CVSS scoring, and remediation. Detection content below is intentionally behavioral and asset-aware because the public sources do not disclose an exact password-change endpoint or CIP packet signature.

3. Source Review and Confidence

Source	Contribution	Reliability	Confidence
CISA ICSA-26-167-05, 2026-06-16	Public ICS advisory, affected products, CVSS, CISA recommended practices, no-known-exploitation statement.	High	High
CISA CSAF JSON for ICSA-26-167-05	Machine-readable vulnerability details, CVSS vectors, product IDs, remediation, revision history, and references.	High	High
Rockwell Automation SD1775	Vendor advisory with corrected firmware version, KEV status, affected catalog numbers, product description, and disclosure context.	High	High
CVE records for CVE-2026-0646 and CVE-2026-0647	Canonical CVE identifiers and linkage to weakness classes.	High	Medium-High pending enrichment beyond advisory text
Defensive telemetry patterns for ICS web/CIP monitoring	Informs detection and hunting recommendations for OT network and asset telemetry.	Medium	Medium

Key facts assessed with high confidence:

- 1794-AENTR and 1794-AENTRXT firmware 2.012 are affected.
- Firmware 2.013 is the corrected version identified by Rockwell and CISA.
- CVE-2026-0646 is a memory-handling issue in CIP protocol request handling that can fault the adapter and require manual reset.
- CVE-2026-0647 is a missing-authentication issue in the embedded web server that can allow unauthenticated password change through a crafted HTTP GET request.
- CISA reports no known public exploitation specifically targeting these vulnerabilities as of publication.

- Rockwell marks KEV status as No and the advisory as corrected.

Confidence caveats:

- Public reporting does not include packet captures, exploit code, exact vulnerable web endpoint, or affected configuration permutations.
- Asset criticality depends on how each adapter is placed in the cell/area architecture and whether the management web interface is reachable outside a tightly controlled OT zone.
- Detection logic should be validated in a lab or maintenance window before production blocking because malformed CIP traffic tests can impact device availability.

4. Key Findings

ID	Finding	Defensive Implication	Priority
F1	CVE-2026-0647 enables unauthenticated password change against the embedded web server.	Exposed management interfaces can be taken over without valid credentials, undermining device administration and recovery.	Critical
F2	CVE-2026-0646 can cause adapter fault and I/O module disconnection through CIP request handling.	A network attacker with CIP reachability can create operational disruption and require manual reset.	High
F3	Both vulnerabilities affect firmware 2.012 and are corrected in 2.013.	Asset inventory and firmware verification are the highest-value first steps.	Critical
F4	The devices sit in a control-system role, not merely an IT management role.	Loss of adapter availability may affect distributed I/O communication with Logix controllers and operational processes.	High
F5	Public sources report no known exploitation, but the attack surfaces are common OT services.	Do not wait for KEV listing; reduce network exposure and monitor now.	Medium-High
F6	Public exploit detail is incomplete.	Detection should combine asset scoping, management-interface telemetry, CIP anomaly monitoring, and engineering-workstation change records rather than rely on a single signature.	Medium

Vulnerability detail matrix:

CVE	Weakness	Affected Surface	CVSS v3.1	CVSS v4.0	Operational Effect	Corrected Version
CVE-2026-0646	CWE-401 Missing Release of Memory after Effective Lifetime	CIP protocol request handling	7.5 High; AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	8.7 High	Adapter fault, loss of connection to associated I/O modules, manual	2.013

					reset required	
CVE-2026-0647	CWE-306 Missing Authentication for Critical Function	Embedded web server	9.4 Critical; AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:H	8.8 High	Unauthorized password change, account takeover, embedded web server availability impact	2.013

Affected product matrix:

Vendor	Product Family	Catalog Numbers	Affected Firmware	Fixed Firmware	Deployment Context
Rockwell Automation	FLEX I/O EtherNet/IP Adapters	1794-AENTR, 1794-AENTRXT	2.012	2.013	Distributed I/O adapter connecting 1794 FLEX I/O modules to EtherNet/IP networks and Logix controllers

5. Threat Context

Industrial attackers do not need a vulnerability to be internet-facing for it to be operationally meaningful. OT compromise paths often start from corporate VPN access, exposed remote-management paths, jump hosts, engineering workstations, contractor laptops, or flat network segments where device management protocols are reachable after an initial foothold. FLEX I/O adapters are attractive because they connect field I/O modules to controller networks; impairing them can create disruption without needing to directly compromise a controller logic project.

The two disclosed issues support different attacker objectives. CVE-2026-0647 is a control and access problem: unauthenticated password change can lock legitimate operators out of the embedded web interface, enable unauthorized device management, or delay recovery during an incident. CVE-2026-0646 is an availability problem: crafted CIP traffic can fault the adapter, sever I/O module connectivity, and force manual intervention. In a manufacturing environment, both outcomes can be leveraged for downtime, process disruption, coercion during ransomware operations, or cover activity during broader intrusion operations.

Scenario	Preconditions	Likely Objective	Defensive Focus
OT insider or compromised engineering workstation reaches adapter web UI	TCP/80 or TCP/443 from engineering or maintenance station to affected adapter	Change embedded web password, deny legitimate access, prepare later manipulation	Web access logs if available, switch/firewall flow logs, engineering workstation process telemetry, change records
Compromised vendor remote-access path reaches plant EtherNet/IP network	Vendor VPN/jump host can reach TCP/44818 or UDP/44818	Trigger adapter fault or validate disruption capability	Remote-access segmentation, CIP traffic baselines, maintenance-window correlation
Ransomware operator pivots from IT into OT-adjacent subnet	Inadequate segmentation between IT, DMZ, and OT device networks	Disrupt I/O communications to increase extortion pressure	East-west network detection, deny-by-default firewall policy, OT asset allowlists
Internet-exposed or	Direct exposure or port-	Opportunistic exploitation,	External exposure scans,

misconfigured remote access to adapter services	forwarded access to embedded web/CIP services	lockout, denial of service	firewall review, rapid isolation and firmware update
---	---	----------------------------	--

MITRE ATT&CK mapping is best understood as technique-level relevance, not evidence of a named campaign:

Matrix	Technique	Name	Rationale
Enterprise	T1190	Exploit Public-Facing Application	If the embedded web server is exposed beyond intended OT zones, CVE-2026-0647 can be used against a network service without authentication.
Enterprise	T1110 / T1098 caveat	Credential or account manipulation pattern	The issue changes web-interface access state, but public reporting does not describe credential guessing or standard account-management APIs. Use this as a conceptual mapping only.
ICS	T0866	Exploitation of Remote Services	Both issues are reachable through network services used for device management or industrial communications.
ICS	T0886	Remote Services	Attack delivery depends on reaching embedded web or EtherNet/IP/CIP services remotely.
ICS	T0814	Denial of Service	CVE-2026-0646 can fault the adapter and disconnect associated I/O modules.
ICS	T0855	Unauthorized Command Message	Crafted CIP or web requests may issue actions not authorized for the requester; exact command semantics are not public.

6. Detection and Hunting

Detection should start from an accurate asset list. If the environment cannot identify 1794-AENTR and 1794-AENTRXT devices, firmware levels, IP addresses, switch ports, controller relationships, and permitted engineering stations, it will be difficult to distinguish malicious probing from routine industrial communication. Prioritize passive network visibility and allowlisted management paths before attempting active vulnerability validation.

Analytic	Telemetry Source	Goal	Notes
HTTP GET requests to adapter management interfaces from non-engineering hosts	Firewall, Zeek, proxy if applicable, switch span, OT NDR	Identify suspicious web access and possible CVE-2026-0647 probing.	Public sources do not disclose the endpoint; hunt on destination asset and method/path anomalies.
Password or configuration change near abnormal web access	Device logs if available, engineering change records, maintenance tickets	Correlate potential unauthenticated password changes with operational	Many embedded devices have limited logging; preserve

		activity.	external flow records.
CIP traffic spikes, malformed requests, repeated errors, or connection resets	OT NDR, Zeek/ICS parsers, NetFlow, controller diagnostics	Identify CVE-2026-0646 probing or fault attempts.	Avoid active fuzzing against production devices.
Adapter fault or I/O module disconnect events	Controller diagnostics, historian/SCADA alarms, maintenance logs	Detect operational symptoms consistent with denial of service.	Correlate with network traffic before and after the fault.
Any direct access from IT, VPN, or vendor subnets to adapter web/CIP services	Firewall and segmentation logs	Find exposure paths that should not exist.	Treat as a control failure even absent exploit evidence.

Example Zeek-style hunting logic for adapter web management access:

```
# Conceptual Zeek notice logic for environments with known FLEX I/O adapter IPs.
# Replace Site::flex_io_adapters and Site::approved_engineering_hosts with local sets.

module LostBoysCyber;

export {
  redef enum Notice::Type += { FLEX_IO_Web_Access_From_Unapproved_Host };
}

event http_request(c: connection, method: string, original_URI: string, unescaped_URI: string, version: string)
{
  if ( c$id$resp_h in Site::flex_io_adapters && method == "GET" )
  {
    if ( c$id$orig_h !in Site::approved_engineering_hosts )
    {
      NOTICE([$note=FLEX_IO_Web_Access_From_Unapproved_Host,
        $conn=c,
        $msg=fmt("HTTP GET to FLEX I/O adapter management interface from unapproved host: %s -> %s URI=%s", c$id$orig_h, c$id$resp_h, original_URI)]);
    }
  }
}
```

Example Suricata rule for non-approved HTTP management access to known adapter addresses:

```
# Tune HOME_NET/FLEX_IO_ADAPTERS and approved source exceptions in the sensor policy.
# This is an exposure/hunt rule, not a confirmed exploit signature.
alert http $HOME_NET any -> $FLEX_IO_ADAPTERS any (msg:"LBC FLEX I/O adapter HTTP GET from non-standard source - investigate CVE-2026-0647 exposure"; flow:to_server,established; http.method; content:"GET"; classtype:attempted-recon; sid:9006082; rev:1; metadata: affected_product Rockwell_1794_AENTR, cve CVE_2026_0647;)
```

Microsoft Defender XDR hunt for engineering workstations contacting adapter web or EtherNet/IP services:

```
// Replace FlexIoAdapterIPs and ApprovedEngineeringHosts with local values.
let Lookback = 30d;
let FlexIoAdapterIPs = dynamic(["10.10.10.10", "10.10.10.11"]);
let ApprovedEngineeringHosts = dynamic(["ENG-WS-01", "ENG-WS-02"]);
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where RemoteIP in (FlexIoAdapterIPs)
| where RemotePort in (80, 443, 44818)
| extend AccessType = case(RemotePort in (80,443), "Embedded web management", RemotePort == 44818, "EtherNet/IP CIP", "Other")
| where DeviceName !in~ (ApprovedEngineeringHosts)
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteIP, RemotePort, AccessType, AccountName, ReportId
```


order by Timestamp desc

Splunk hunt for abnormal access to affected adapters:

```
index=netfw earliest=-30d (dest_port=80 OR dest_port=443 OR dest_port=44818)
[ | inputlookup flex_io_adapters.csv | fields dest_ip ]
| lookup approved_engineering_hosts host as src OUTPUT host as approved_src
| where isnull(approved_src)
| stats earliest(_time) as first_seen latest(_time) as last_seen count values(dest_port) as ports
values(action) as actions by src dest_ip user
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

Hunt triage questions:

- Is the source host an approved engineering workstation, controller-management host, jump server, or vendor support endpoint?
- Did access occur during an approved maintenance window or immediately before an adapter fault, I/O disconnect, or web-login failure report?
- Is the destination confirmed as 1794-AENTR or 1794-AENTRXT firmware 2.012?
- Was the HTTP request path consistent with routine browsing, or did it resemble direct parameterized configuration changes?
- Did the same source scan additional OT assets or attempt EtherNet/IP, Modbus, DNP3, SMB, RDP, or VPN access?

7. Recommendations

Priority	Owner	Recommendation	Target State
Critical	OT Engineering	Inventory all 1794-AENTR and 1794-AENTRXT devices and verify firmware versions.	Complete list of affected and unaffected adapters with IP, cell/area, controller relationship, firmware, and maintenance owner.
Critical	OT Engineering / Maintenance	Upgrade affected firmware 2.012 devices to corrected firmware 2.013.	No production affected adapter remains on firmware 2.012 without documented exception and compensating controls.
Critical	Network Engineering	Restrict adapter web management and EtherNet/IP/CIP access to approved engineering hosts, controllers, and maintenance jump paths.	Deny-by-default segmentation between IT, vendor VPN, DMZ, and OT device networks.
High	SOC / Detection Engineering	Deploy asset-aware monitoring for HTTP GET requests to adapter web interfaces and unexpected TCP/44818 access.	Alerts include source identity, destination asset owner, maintenance-window context, and firmware status.
High	OT Operations	Correlate adapter faults, I/O module disconnects, and manual resets with network telemetry.	Operational events can be quickly assessed for malicious, accidental, or maintenance-related causes.
Medium-High	Vulnerability Management	Track exceptions for devices that cannot be patched immediately.	Each exception has compensating controls, owner, expiration date, and residual-risk approval.

Medium	Incident Response	Update OT incident playbooks for embedded web password takeover and CIP-triggered adapter DoS.	Responders know how to isolate the source path, preserve logs, validate firmware, reset credentials, and restore adapter operation.
--------	-------------------	--	---

Immediate action plan:

- Within 24 hours: search asset inventory, switch MAC tables, Rockwell project documentation, and OT NDR inventory for 1794-AENTR and 1794-AENTRXT devices.
- Within 72 hours: validate firmware version 2.012 exposure, confirm whether TCP/80, TCP/443, TCP/44818, or UDP/44818 are reachable from non-approved sources, and open firmware-update change records.
- Within the next maintenance cycle: update to firmware 2.013, rotate embedded web-interface credentials where takeover is suspected or cannot be ruled out, and document rollback/recovery steps.
- After remediation: keep the detection logic active as exposure monitoring because future OT vulnerabilities often reuse the same risky management paths.

Operational guardrails:

- Do not run unauthenticated exploit validation or CIP fuzzing against production adapters.
- Prefer passive verification and vendor-supported firmware validation methods.
- Treat direct internet exposure of embedded web or EtherNet/IP services as an urgent architecture issue regardless of firmware status.
- If a device cannot be patched, restrict management access to a short allowlist, require VPN plus jump-host controls, block IT-to-OT direct paths, and monitor for any non-maintenance access.
- Capture before/after firmware evidence for audit, including screenshot or exported inventory showing catalog number, IP, firmware, and update time.

8. References

- [1] CISA, ICSA-26-167-05: Rockwell Automation FLEX I/O EtherNet/IP Adapters, 2026-06-16. <https://www.cisa.gov/news-events/ics-advisories/icsa-26-167-05>
- [2] CISA CSAF JSON, ICSA-26-167-05. https://raw.githubusercontent.com/cisagov/CSAF/develop/csaf_files/OT/white/2026/icsa-26-167-05.json
- [3] Rockwell Automation, SD1775: FLEX I/O Dual-port EtherNet/IP Adapters – Multiple Vulnerabilities, 2026-06-16. <https://www.rockwellautomation.com/en-us/trust-center/security-advisories/advisory.SD1775.html>
- [4] CVE.org, CVE-2026-0646. <https://www.cve.org/CVERecord?id=CVE-2026-0646>
- [5] CVE.org, CVE-2026-0647. <https://www.cve.org/CVERecord?id=CVE-2026-0647>
- [6] CWE-401: Missing Release of Memory after Effective Lifetime. <https://cwe.mitre.org/data/definitions/401.html>
- [7] CWE-306: Missing Authentication for Critical Function. <https://cwe.mitre.org/data/definitions/306.html>
- [8] CISA, Recommended Practices for Industrial Control Systems. <https://www.cisa.gov/resources-tools/resources/ics-recommended-practices>
- [9] CISA, Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies. https://www.cisa.gov/sites/default/files/publications/Cybersecurity_Best_Practices_for_Industrial_Control_Systems.pdf